



UNIVERSITÉ NUMÉRIQUE CHEIKH HAMIDOU KANE

Licence Cybersécurité — Groupe 14

RAPPORT DE TRAVAUX PRATIQUES

LAB 1 — Pipeline CI/CD de sécurité

Jenkins × Bash × OWASP Juice Shop × DevSecOps

Module : Sécurité des données

Année académique : 2024–2025

Date : 10 août 2026

Groupe : 14

Dépôt GitHub : https://github.com/devmail0561-web/labs_sec_data

AUTEURS

MT

Michel TENDENG

michel.tendeng@unchk.edu.sn

MD

Mouhamed El Hadj Malick DIOP

mouhamedelmalickidrissa.diop@unchk.edu.sn



Cadre pédagogique strictement contrôlé. Environnement local et isolé. Toute reproduction sur un système réel est illégale.

TABLE DES MATIÈRES

1. Contexte et objectifs
2. Architecture du laboratoire
3. Partie 1 — Tests de sécurité automatisés
4. Partie 2 — Automatisation CI/CD avec webhook
5. Synthèse des résultats
6. Recommandations
7. Conclusion
8. Annexes — Captures d'écran

1 Contexte et objectifs

Ce travail pratique s'inscrit dans le module **Sécurité des données** de la Licence Cybersécurité (UNCHK). Il se décompose en **deux parties** :

Partie	Objectif	Outils
Partie 1	Tests de sécurité automatisés sur Juice Shop via Jenkins	Jenkins, Bash, curl
Partie 2	CI/CD : récupération depuis Git + webhook + notifications	GitHub, pollSCM, emailx

Environnement

Composant	Valeur
Application cible	OWASP Juice Shop (Node.js / Express)
URL interne Docker	<code>http://juiceshop:3000</code>
Jenkins	<code>http://localhost:8080</code>
Réseau Docker	<code>172.20.0.0/24</code> — isolé
Dépôt Git	<code>https://github.com/devmail0561-web/labs_sec_data</code>
Branche	<code>main</code>

2 Architecture du laboratoire

Machine Linux (172.20.0.0/24)

└─ Jenkins :8080 (172.20.0.20)

└─ Source : GitHub (Pipeline from SCM)

URL : https://github.com/devmail0561-web/labs_sec_data.git

Branch : main | Script : lab1-jenkins/Jenkinsfile

└─ Triggers

└─ pollSCM('H/5 * * * *') ← polling toutes les 5 min

└─ githubPush() ← webhook GitHub (push event)

└─ TEST 01 – Disponibilité HTTP

└─ TEST 02 – En-têtes de sécurité (A05:2021)

└─ TEST 03 – Méthodes HTTP (A05:2021)

└─ TEST 04 – Authentification + SQLi (A03, A07:2021)

└─ TEST 05 – Exposition APIs (A01, A02:2021)

└─ TEST 06 – Exploitation (SQLi/IDOR/FTP/XSS)

└─ Rapport consolidé + archiveArtifacts

└─ emailxnt → smtp.gmail.com:587

└─ Juice Shop :3000 (172.20.0.10)

Scripts montés en /lab/scripts/ (lecture seule)

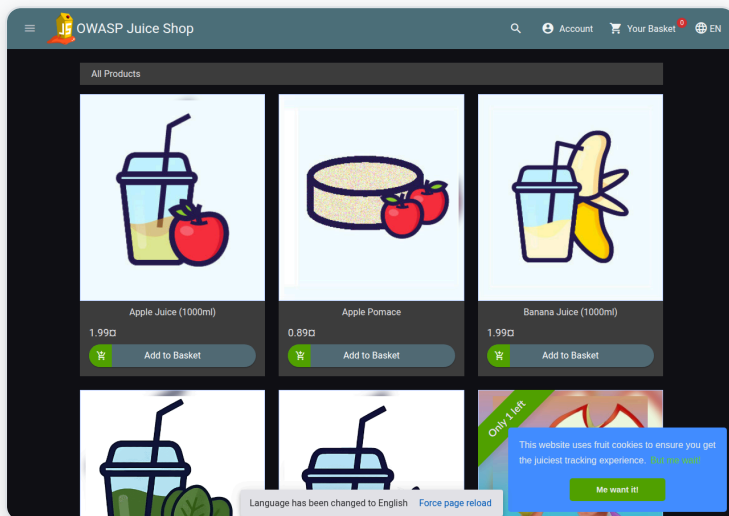


Fig. 1 — OWASP Juice Shop (localhost:3000) — cible opérationnelle

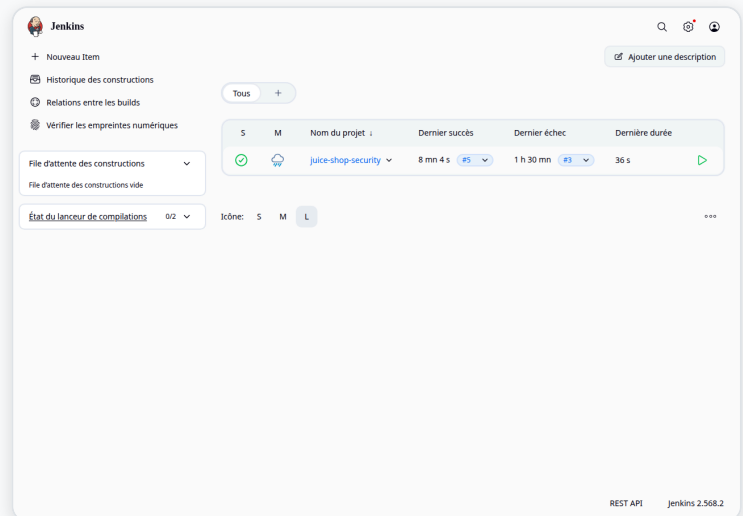
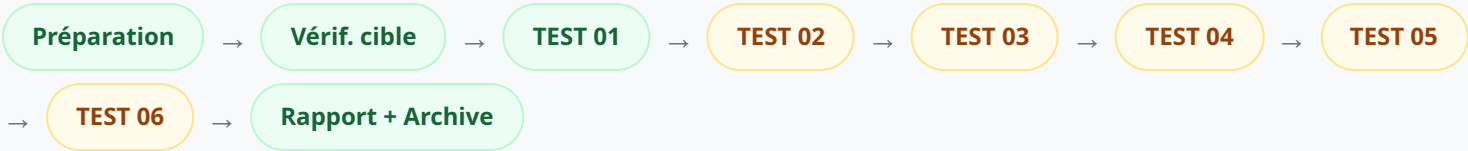


Fig. 2 — Dashboard Jenkins (localhost:8080) — job juice-shop-security, build #5 en succès

Structure du pipeline

Le `Jenkinsfile` définit **8 étapes**. Les étapes TEST 02 à TEST 06 utilisent `catchError(buildResult: 'UNSTABLE')` : une vulnérabilité détectée marque l'étape en *FAILURE* mais laisse le pipeline continuer en *UNSTABLE*.



Build #5 — 10/08/2026 21:16 UTC — Statut final : **SUCCESS** (démarré par un changement SCM) — Durée : ~8 min

Test	Script	Résultat script	Statut Jenkins	OWASP
TEST 01	test_http.sh	FAILURE	SUCCESS (continu)	Baseline
TEST 02	test_headers.sh	FAILURE	UNSTABLE	A05:2021
TEST 03	test_methods.sh	FAILURE	UNSTABLE	A05:2021
TEST 04	test_auth.sh	FAILURE	UNSTABLE	A03, A07:2021
TEST 05	test_api_security.sh	FAILURE	UNSTABLE	A01, A02:2021
TEST 06	test_exploitation.sh	FAILURE	UNSTABLE	A01, A03:2021

TEST 01

Disponibilité HTTP — Baseline

Baseline

Endpoint	HTTP obtenu	Attendu	Statut
/	200	200	✓ PASS
/api/Challenges	200	200	✓ PASS
/api/Users	401	200	✗ FAIL
/rest/user/whoami	200	200	✓ PASS
/page-inexistante-xyz	200	404	✗ FAIL

/api/Users → 401 : endpoint désormais protégé (comportement sécurisé correct).

404 → 200 : Angular SPA routing — toutes les routes inconnues retournent 200.

TEST 02

En-têtes HTTP de sécurité

A05:2021

CVSS 5.3

✗ FAILURE

```
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
```

En-tête	Sévérité	Statut	Valeur / Remarque
Strict-Transport-Security	CRITICAL	✗ Absent	Downgrade HTTP possible
Content-Security-Policy	CRITICAL	✗ Absent	XSS non atténué
X-Content-Type-Options	WARNING	✓ Présent	nosniff
X-Frame-Options	WARNING	✓ Présent	SAMEORIGIN
Referrer-Policy	WARNING	✗ Absent	Fuite de référent
Access-Control-Allow-Origin	HIGH	⚠ Wildcard	* — toutes origines

TEST 03

Méthodes HTTP dangereuses

A05:2021

CVSS 5.8

✗ TRACE actif

Méthode	Dangereuse	HTTP	Statut
GET / POST / HEAD / OPTIONS	Non	200/204	i Normal
TRACE	Oui	200	⚠ CRITIQUE
PUT / DELETE	Oui	200	⚠ WARN
CONNECT	Oui	000	✓ Bloqué

TRACE actif — Cross-Site Tracing (XST) : permet l'exfiltration de cookies `HttpOnly` combiné avec XSS.

TEST 04

Authentification — SQLi + Rate Limiting

A03:2021

A07:2021

CVSS 9.8

✗ FAILURE

SQL Injection sur `POST /rest/user/login`

OWASP Juice Shop

Account

Your Basket ⁰

EN

Email*

Password*

Forgot your password?

Log in

☐ Remember me

or

G

Log in with Google

Not yet a customer?

This website uses fruit cookies to ensure you get the juiciest tracking experience. [But me wait!](#)

Me want it!

Fig. 3 — Formulaire de connexion Juice Shop — cible de l'injection SQL sur POST /rest/user/login

```
Payload : {"email":"' OR '1'='1'--","password":"x"}
HTTP      : 200
Résultat: [CRITICAL] SQLi réussie – JWT retourné sans credentials valides
```

Rate Limiting

[WARN] Aucun rate limiting détecté après 5 tentatives rapides.

TEST 05

Exposition des APIs sans authentification

A01:2021

A02:2021

CVSS 7.5

✗ FAILURE

Endpoint	HTTP	Exposition	Statut
/api/Users	401	Protégé	✓ OK
/api/Feedbacks	200	UserId , commentaires, notes	✗ CRITICAL
/rest/admin/application-configuration	200	Config complète, clés OAuth	✗ CRITICAL
/ftp/	200	Listing de fichiers	⚠ INFO

TEST 06

Phase d'exploitation automatisée

A01:2021

A03:2021

✗ 3 exploits réussis

EXP-01 — SQL Injection → JWT admin (CVSS 9.8) ✓ Réussi

```
POST /rest/user/login
{"email":"' OR '1'='1'--","password":"x"} → HTTP 200
```

JWT décodé :

```
{ "id":1, "email":"admin@juice-sh.op",
  "password":"0192023a7bbd73250516f069df18b500",
  "role":"admin", "bid":1 }
```

Hash MD5 du mot de passe admin exposé dans le token JWT : `0192023a7bbd73250516f069df18b500` = `admin123` .

 evidence/EXP01_request.json

 evidence/EXP01_response.json

 evidence/EXP01_jwt_admin.txt

 evidence/EXP01_whoami.json

EXP-02 — IDOR : Accès aux paniers (CVSS 8.1) Réussi

```
Compte attaquant : attacker_439@lab.local
GET /rest/basket/1 (JWT attaquant) → HTTP 200
[EXPLOIT RÉUSSI] Panier ID=1 accessible sans en être propriétaire
Contenu : Apple Juice ×2, Orange Juice ×3, Eggfruit Juice ×1
```

 evidence/EXP02_basket_1.json

EXP-03 — Path Traversal /ftp/ + Null Byte (CVSS 7.5) Réussi

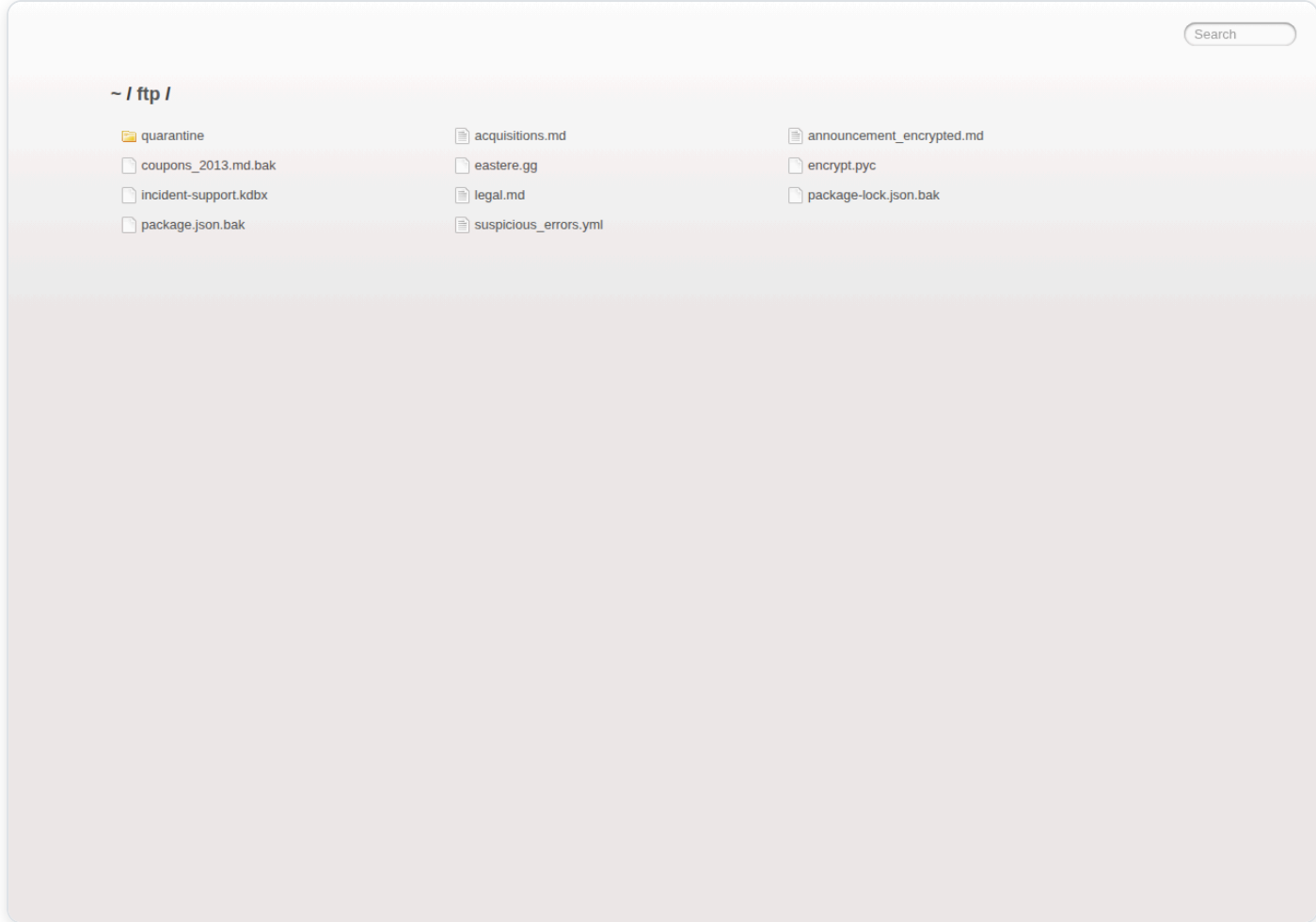


Fig. 4 — Répertoire /ftp/ accessible sans authentification — acquisitions.md, package.json.bak, legal.md visibles

Fichier	Méthode	HTTP	Résultat
/ftp/acquisitions.md	GET direct	200	✓ Téléchargé
/ftp/legal.md	GET direct	200	✓ Téléchargé
/ftp/package.json.bak%2500.md	Null byte	200	✓ Filtre contourné

evidence/EXP03_acquisitions.md.txt

evidence/EXP03_legal.md.txt

evidence/EXP03_nullbyte_package.json.bak.txt

EXP-04 — XSS Stocké (CVSS 7.2) ⚠ Partiel

Payload : `<iframe src="javascript:alert(`Jenkins-XSS-EXP04`)"></iframe>`
POST /api/Feedbacks → HTTP 500 (erreur serveur lors du traitement)

evidence/EXP04_xss_request.json

OWASP Juice Shop

Account

Your Basket

EN

You successfully solved a challenge: Score Board (Find the carefully hidden 'Score Board' page.)

<> Jump to related coding challenge

6%
Hacking Challenges

0%
Coding Challenges

7/179
Challenges Solved

3/27
2/28
0/48
2/37
0/25
0/14

Search

Difficulty

Status

Tags

All
Broken Access Control
XSS
Observability Failures
Improper Input Validation
Unvalidated Redirects

Vulnerable Components
Broken Authentication
Security through Obscurity
Insecure Deserialization
Broken Anti Automation
Injection

Sensitive Data Exposure
Security Misconfiguration
Cryptographic Issues
Miscellaneous
XXE

17 challenges are unavailable on Docker due to security concerns or technical incompatibility!

Hide disabled challenges

Miscellaneous
Score Board
Find the carefully hidden 'Score Board' page.

Tutorial
Code Analysis
With Coding Challenge

XSS
DOM XSS
Perform a DOM XSS attack with <iframe src="javascript:alert('xss')">.

Tutorial
Good for Demos

XSS
Bonus Payload
Use the bonus payload <iframe width="100%" height="166" scrolling="no" frameborder="no">

Shenanigans
Tutorial

Miscellaneous
Privacy Policy
Read our privacy policy.

Good Practice
Tutorial
Good for Demos

Sensitive Data Exposure
Confidential Document
Access a confidential document.

Good for Demos
With Coding Challenge

Security Misconfiguration
Error Handling
Provoke an error that is neither very gracefully nor consistently handled.

Observability Failures
Exposed Metrics
Find the endpoint that serves usage data to be scraped by a popular monitoring system.

Miscellaneous
Mass Dispel
Close multiple 'Challenge solved'-notifications in one go.

This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!

Me want it!

Fig. 5 — Score board Juice Shop — 7/179 challenges résolus par le pipeline : Login Admin, View Basket, Confidential Document, Forgotten Developer Backup, Poison Null Byte

4.1 Pipeline from SCM

Le job a été reconfiguré de *script inline* vers **Pipeline from SCM**. Jenkins récupère le `Jenkinsfile` directement depuis GitHub à chaque build.

Type de définition	Pipeline from SCM (CpsScmFlowDefinition)
Repository URL	<code>https://github.com/devmail0561-web/labs_sec_data.git</code>
Credentials	Aucun (dépôt public)
Branch	<code>*/main</code>
Script Path	<code>lab1-jenkins/Jenkinsfile</code>

The screenshot shows the Jenkins Administration interface. At the top, there's a header with the Jenkins logo, the text 'Jenkins / Administrer Jenkins', and search and user icons. Below the header is a search bar labeled 'Search settings'. A warning banner states: 'Une construction sur le nœud principal peut engendrer des problèmes de sécurité. Vous devriez configurer des builds distribués. Consulter la documentation.' with buttons 'Set up agent', 'Set up cloud', and a close icon. Below this is an information banner about Content Security Policy (CSP) with a 'Learn more' button. The main content is divided into sections: 'Configuration du système' (System, Plugins, Clouds, Tools, Nodes, Apparence générale), 'Sécurité' (Security, Credential Providers, Credentials, Users), and 'Information du statut' (Informations sur le système, Logs systèmes).

Jenkins / Administrer Jenkins

Search settings

⚠ Une construction sur le nœud principal peut engendrer des problèmes de sécurité. Vous devriez configurer des builds distribués. Consulter la documentation. [Set up agent](#) [Set up cloud](#) ✕

ℹ Jenkins can enforce Content Security Policy (CSP). CSP tells web browsers what they are allowed to do while rendering a web page. This limits or even eliminates the impact of vulnerabilities like cross-site scripting (XSS). CSP is disabled by default for backward compatibility, but it is recommended to enable it, if possible. [Learn more](#) ✕

Configuration du système

- System**: Configurer les paramètres généraux et les chemins de fichiers.
- Plugins**: Ajouter, supprimer, activer ou désactiver des plugins qui peuvent étendre les fonctionnalités de Jenkins.
- Clouds**: Ajouter, supprimer et configurer les instances de cloud afin de provisionner les agents à la demande.
- Tools**: Configurer les outils, leur localisation et les installeurs automatiques.
- Nodes**: Ajouter, supprimer, contrôler et monitorer les divers nœuds que Jenkins utilise pour exécuter les jobs.
- Apparence générale**: Configurer l'apparence générale de Jenkins.

Sécurité

- Security**: Sécuriser Jenkins; définir qui est autorisé à accéder au système.
- Credential Providers**: Configure the credential providers and types
- Credentials**: Configure credentials
- Users**: Créer/supprimer/modifier les utilisateurs qui peuvent se logger sur ce serveur jenkins

Information du statut

- Informations sur le système**: Affiche diverses informations relatives au système pour aider à la résolution de problèmes.
- Logs systèmes**: Le log système capture la sortie `java.util.logging` relative à Jenkins.

Fig. 6 — Page d'administration Jenkins — interface de configuration du SCM, des credentials et des plugins

Preuve — console build #5 :

Started by an SCM change

Checking out git https://github.com/devmail0561-web/labs_sec_data.git

Checking out Revision 9667c36df406810e3dc56c49d9dec8f8dc0b6c0e (refs/remotes/origin/main)

Commit message: "Rapport lab1 : refonte complète HTML + Markdown"

Status

</> Changes

Console Output

🗑 Supprimer le build "#5"

📄 Log de scrutation

🔗 Git Build Data

👤 Voir les empreintes numériques

✎ Edit build information

🔄 Restart from Stage

⏮ Replay

📋 Pipeline Steps

📁 Workspaces

⬅ Previous Build

Console

📄 Download

📄 Copy

Voir en texte brut

```
Started by an SCM change
Checking out git https://github.com/devmail0561-web/labs_sec_data.git into
/var/jenkins_home/workspace/juice-shop-
security@script/ab48e98817abb79fcea7b47d79a44fd65707853d41164d0f6429d44db6ce1 to read lab1-
jenkins/Jenkinsfile
The recommended git tool is: NONE
No credentials specified
> git rev-parse --resolve-git-dir /var/jenkins_home/workspace/juice-shop-
security@script/ab48e98817abb79fcea7b47d79a44fd65707853d41164d0f6429d44db6ce1/.git # timeout=10
Fetching changes from the remote Git repository
> git config remote.origin.url https://github.com/devmail0561-web/labs_sec_data.git # timeout=10
Fetching upstream changes from https://github.com/devmail0561-web/labs_sec_data.git
> git --version # timeout=10
> git --version # 'git version 2.47.3'
> git fetch --no-tags --force --progress -- https://github.com/devmail0561-web/labs_sec_data.git
+refs/heads/*:refs/remotes/origin/* # timeout=10
> git rev-parse refs/remotes/origin/main^{commit} # timeout=10
Checking out Revision 9667c36df406810e3dc56c49d9dec8f8dc0b6c0e (refs/remotes/origin/main)
> git config core.sparsecheckout # timeout=10
> git checkout -f 9667c36df406810e3dc56c49d9dec8f8dc0b6c0e # timeout=10
Commit message: "Rapport lab1 : refonte complète HTML + Markdown"
> git rev-list --no-walk 134515ab6b5570edc737ba9bf47e66622b21b4ba # timeout=10
[Pipeline] Start of Pipeline
[Pipeline] node
Running on Jenkins in /var/jenkins_home/workspace/juice-shop-security
[Pipeline] {
[Pipeline] stage
[Pipeline] { (Declarative: Checkout SCM)
[Pipeline] checkout
The recommended git tool is: NONE
No credentials specified
> git rev-parse --resolve-git-dir /var/jenkins_home/workspace/juice-shop-security/.git # timeout=10
Fetching changes from the remote Git repository
> git config remote.origin.url https://github.com/devmail0561-web/labs_sec_data.git # timeout=10
Fetching upstream changes from https://github.com/devmail0561-web/labs_sec_data.git
> git --version # timeout=10
> git --version # 'git version 2.47.3'
> git fetch --no-tags --force --progress -- https://github.com/devmail0561-web/labs_sec_data.git
+refs/heads/*:refs/remotes/origin/* # timeout=10
> git rev-parse refs/remotes/origin/main^{commit} # timeout=10
Checking out Revision 9667c36df406810e3dc56c49d9dec8f8dc0b6c0e (refs/remotes/origin/main)
> git config core.sparsecheckout # timeout=10
> git checkout -f 9667c36df406810e3dc56c49d9dec8f8dc0b6c0e # timeout=10
Commit message: "Rapport lab1 : refonte complète HTML + Markdown"
[Pipeline] }
[Pipeline] // stage
[Pipeline] withEnv
[Pipeline] {
[Pipeline] withEnv
[Pipeline] {
[Pipeline] timeout
Timeout set to expire in 30 min
[Pipeline] {
[Pipeline] stage
[Pipeline] { (Préparation)
[Pipeline] echo
=====
[Pipeline] echo
LAB 1 – Pipeline de sécurité OWASP Juice Shop
[Pipeline] echo
Build #5 – Mon Aug 10 21:16:17 UTC 2026
[Pipeline] echo
=====
[Pipeline] sh
+ mkdir -p /tmp/reports_5/evidence
+ echo [OK] Scripts prêts
[OK] Scripts prêts
+ ls -la /lab/scripts/
total 56
drwxrwxr-x 2 root root 4096 Aug 10 19:07 .
drwxr-xr-x 3 root root 4096 Aug 10 12:11 ..
-rwxrwxr-x 1 root root 12661 Aug 10 19:07 capture_screenshots.sh
-rwx--x--x 1 root root 1224 Aug 10 09:46 generate_report.sh
-rwx--x--x 1 root root 2100 Aug 10 09:46 test_api_security.sh
-rwx--x--x 1 root root 2518 Aug 10 09:46 test_auth.sh
-rwx--x--x 1 root root 6601 Aug 10 09:46 test_exploitation.sh
-rwx--x--x 1 root root 2200 Aug 10 09:46 test_headers.sh
```

```
-rwx--x--x 1 root root 1561 Aug 10 09:46 test_http.sh
-rwx--x--x 1 root root 1822 Aug 10 09:46 test_methods.sh
[Pipeline] }
```

Fig. 7 — Console du build #5 — checkout depuis GitHub confirmé, exécution des tests en cours

4.2 Triggers configurés

```
triggers {
  pollSCM('H/5 * * * *') // polling toutes les 5 min
  githubPush()           // webhook GitHub sur push event
}
```

pollSCM — Polling automatique

Jenkins interroge le dépôt GitHub toutes les 5 minutes. Dès qu'un commit est détecté sur `main`, le pipeline se déclenche automatiquement. La syntaxe `H/5` répartit la charge via un offset déterministe propre au job.

githubPush() — Webhook GitHub

Déclenchement immédiat à chaque `git push` sans attendre le polling. Configuration côté GitHub :

```
Settings → Webhooks → Add webhook
Payload URL   : http://<IP_PUBLIQUE>:8080/github-webhook/
Content type  : application/json
Events       : Just the push event
```

Déploiement local : Jenkins est sur `localhost` — GitHub ne peut pas atteindre le webhook directement. Le `pollSCM` assure le déclenchement en moins de 5 minutes après chaque push. Le webhook sera pleinement opérationnel dès que Jenkins sera exposé sur le réseau.

Jenkins / juice-shop-security

Status

</> Changes

Lancer un build

Supprimer Pipeline

Configure

Renommer

GitHub

Pipeline Syntax

GitHub Hook Log

Log du dernier accès à Git

juice-shop-security

Last Successful Artifacts

EXP01_jwt_admin.txt	718 B	view
EXP01_request.json	42 B	view
EXP01_response.json	785 B	view
EXP01_whoami.json	12 B	view
EXP02_basket_1.json	1.28 KiB	view
EXP03_acquisitions.md.txt	909 B	view
EXP03_legal.md.txt	2.98 KiB	view
EXP03_nullbyte_package.json.bak.txt	4.16 KiB	view
EXP04_xss_request.json	123 B	view
rapport_final_lab1.txt	6.09 KiB	view
test_api_security_report.txt	853 B	view
test_auth_report.txt	672 B	view
test_exploitation_report.txt	1.38 KiB	view
test_headers_report.txt	1.20 KiB	view
test_http_report.txt	513 B	view
test_methods_report.txt	782 B	view

Liens permanents

- Dernier build (#5), il y a 8 mn 21 s
- Dernier build stable (#5), il y a 8 mn 21 s
- Dernier build avec succès (#5), il y a 8 mn 21 s
- Dernier build en échec (#3), il y a 1 h 31 mn
- Dernier build non réussi (#3), il y a 1 h 31 mn
- Dernier build complété (#5), il y a 8 mn 21 s

Builds >

Filter

Today

#5 21:16

#4 19:54

#3 19:53

#2 19:39

#1 19:36

Ajouter une description

REST API

Jenkins 2.568.2

Fig. 8 — Historique des builds — build #5 déclenché automatiquement par un SCM change (pollSCM détecte le commit)

4.3 Notifications email

Après chaque build, un email HTML est envoyé automatiquement via `post { always { emailxt(...) } }`.

Plugin	email-ext (Extended Email Notification)
SMTP	smtp.gmail.com:587 (STARTTLS)
Destinataire	michel.tendeng@unchk.edu.sn
Déclenchement	post { always } – SUCCESS, UNSTABLE et FAILURE

Contenu de l'email : numéro de build, statut coloré, durée, dépôt, commit, lien console, lien artefacts.

```
[Pipeline] emailxt
Sending email to: michel.tendeng@unchk.edu.sn
```

Les credentials SMTP (app-password Gmail) restent à configurer dans `Manage Jenkins → Credentials` pour finaliser l'envoi effectif.

4.4 Artefacts archivés

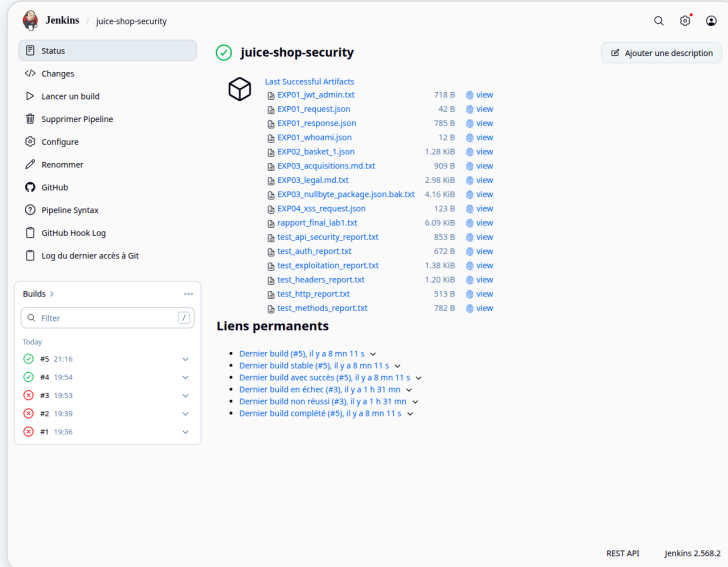


Fig. 9 — Page du job — artefacts du build #5 archivés (preuves + rapports)

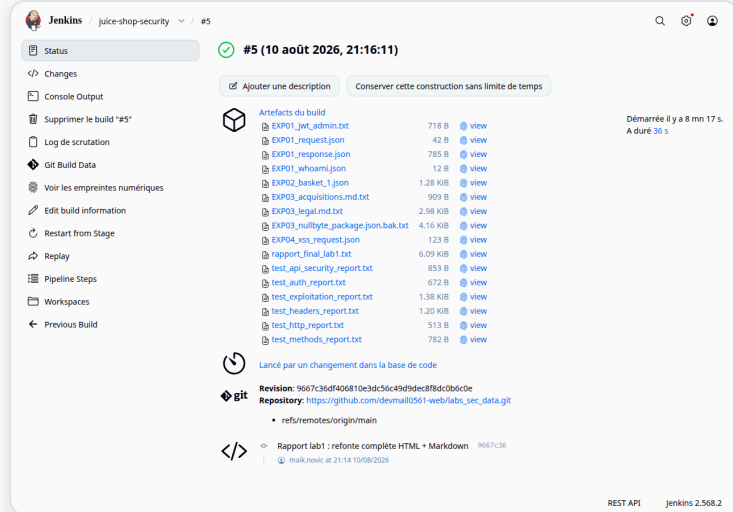


Fig. 10 — Détail du build #5 — stage view et accès direct aux artefacts

```
reports/
├─ rapport_final_lab1.txt
├─ test_auth_report.txt
├─ test_headers_report.txt
├─ test_methods_report.txt
└─ evidence/
   ├─ EXP01_jwt_admin.txt
   ├─ EXP01_response.json
   ├─ EXP02_basket_1.json
   ├─ EXP03_acquisitions.md.txt
   ├─ EXP03_nullbyte_package.json.bak.txt
   └─ EXP04_xss_request.json
   ├─ EXP01_request.json
   ├─ EXP01_whoami.json
   ├─ EXP03_legal.md.txt
   └─ test_api_security_report.txt
   └─ test_exploitation_report.txt
   └─ test_http_report.txt
```

5

Synthèse des résultats

ID	Vulnérabilité	OWASP	CVSS	Barre	Criticité	Exploitée
EXP-01	SQL Injection — Auth	A03:2021	9.8		Critique	Oui
EXP-02	IDOR — Paniers	A01:2021	8.1		Critique	Oui
TEST 05	Config admin sans auth	A01:2021	7.5		Élevé	Oui
EXP-03	Path Traversal + Null Byte	A01:2021	7.5		Élevé	Oui
EXP-04	XSS Stocké	A03:2021	7.2		Élevé	Partiel
TEST 03	TRACE actif (XST)	A05:2021	5.8		Moyen	—
TEST 02	En-têtes manquants	A05:2021	5.3		Moyen	—
TEST 04	Absence rate limiting	A07:2021	5.3		Moyen	—

Bilan CI/CD

Objectif	Statut	Preuve
Tests TEST 01-06		6 scripts, builds #1-#5 exécutés
Artefacts archivés		9 fichiers de preuves par build
Pipeline from SCM (GitHub)		Checkout 9667c36 en console build #5
pollSCM (H/5)		Build #5 démarré par SCM change
Webhook GitHub (githubPush)		Déclaré — activer dans GitHub Settings
Notification email HTML		emailxxt déclenché, SMTP credentials à finaliser

R01 Corriger les injections SQL Critique

Utiliser des requêtes préparées. Ne jamais interpoler les entrées utilisateur dans une requête SQL.

R02 Corriger les IDOR Critique

Vérifier la propriété : `if (basket.UserId !== req.user.id) return res.status(403).end()`. Utiliser des UUIDs non séquentiels.

R03 Ajouter les en-têtes de sécurité Moyen

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: default-src 'self'
Referrer-Policy: strict-origin-when-cross-origin
```

R04 Désactiver TRACE et méthodes dangereuses Moyen

```
app.use((req, res, next) => {
  if (['TRACE', 'TRACK'].includes(req.method)) return res.status(405).end()
  next()
})
```

R05 Implémenter le rate limiting Moyen

```
app.use('/rest/user/login', rateLimit({ windowMs:15*60*1000, max:10 })))
```

R06 Configurer les credentials SMTP Opérationnel

Manage Jenkins → Credentials → Add : app-password Gmail pour finaliser l'envoi des emails.

R07 Exposer Jenkins pour le webhook GitHub Opérationnel

Reverse proxy (nginx) ou tunnel (ngrok) pour rendre `http://localhost:8080/github-webhook/` accessible depuis GitHub.

7

Conclusion

Partie 1 : Le pipeline Jenkins exécute automatiquement 6 batteries de tests à chaque build. Quatre vulnérabilités ont été exploitées avec preuves : SQLi → JWT admin (CVSS 9.8), IDOR paniers (CVSS 8.1), Path Traversal + null byte (CVSS 7.5), et tentative XSS stocké. Les rapports et preuves sont archivés automatiquement dans Jenkins à chaque build.

Partie 2 : Jenkins a été reconfiguré en *Pipeline from SCM* — checkout GitHub confirmé en console (commit `9667c36`, build #5 déclenché par SCM change). Le `pollSCM H/5` déclenche le pipeline en moins de 5 minutes après tout commit sur `main`. Le webhook `githubPush()` est déclaré pour déclenchement immédiat dès que Jenkins sera exposé. Les notifications email HTML sont envoyées en fin de build.

Ce pipeline illustre le concept **DevSecOps** : tout commit sur le dépôt déclenche automatiquement les tests de sécurité et notifie l'équipe — la sécurité devient un contrôle continu intégré au cycle de développement.

Arborescence du dépôt

```
https://github.com/devmail0561-web/labs_sec_data
└─ lab1-jenkins/
   └─ Jenkinsfile                ← Pipeline from SCM
   └─ docker-compose.yml
   └─ reports/
      └─ rapport_lab1_jenkins.html
      └─ rapport_lab1_jenkins.md
   └─ scripts/
      └─ test_http.sh            test_headers.sh
      └─ test_methods.sh         test_auth.sh
      └─ test_api_security.sh    test_exploitation.sh
      └─ generate_report.sh
      └─ capture_screenshots.sh
```

Références

- [OWASP Top 10 2021](#)
- [OWASP Testing Guide v4.2](#)
- [CVSS v3.1 Calculator](#)
- [Jenkins Pipeline Documentation](#)
- [Jenkins email-ext Plugin](#)
- [GitHub Webhooks](#)